

Assessing Governance, Risk, and Compliance (GRC) for an Organization

Name: [Solomon Mwaura]

Date: February 11, 2026

Section 1: Define GRC Objectives and Scope

1.1 Objectives The primary objective of this GRC assessment is to modernize DataTrust Solutions' framework to match its rapid organizational growth. Specifically, the assessment aims to:

1. **Enhance Compliance:** Close gaps in SOC 2 and GDPR adherence to avoid regulatory penalties and build client trust.
2. **Strengthen Risk Management:** Transition from manual, reactive risk tracking to a proactive, automated risk management strategy focused on cybersecurity and operational resilience.
3. **Unify Governance:** Centralize oversight to align IT and business strategies, ensuring governance supports long-term growth rather than just reactive incident management.

1.2 Scope This assessment covers the following areas of DataTrust Solutions:

- **Departments:** IT, Operations, and Compliance.
 - **Systems:** Cloud Database (Client Data), IT Service Management (ITSM) Platform, and the Intrusion Detection System (IDS).
 - **Regulatory & Policy Focus:** SOC 2 (Security/Availability), GDPR (Data Privacy/Transfer), and internal information security policies.
-

Section 2: Evaluate Existing Governance Structures

2.1 Governance Strengths

- **Established IT Operations:** Basic operational policies are in place within the IT department.
- **Incident Response Mechanism:** Regular meetings occur to address immediate incident responses, indicating a functional, albeit reactive, operational command.
- **Tool Utilization:** Usage of ITSM and IDS suggests a foundational layer of technical governance is already established.

2.2 Governance Weaknesses

- **Siloed & Incomplete Policies:** Current policies focus almost exclusively on IT operations, neglecting broader organizational governance and data privacy strategy.
- **Decentralized Oversight:** Responsibilities are scattered across departments with no central GRC owner, leading to accountability gaps.
- **Reactive Focus:** Governance meetings are irregular and driven by incident response (firefighting) rather than proactive strategic planning.

2.3 Recommendations

- **Establish a GRC Committee:** Create a centralized steering committee comprising leads from IT, Operations, and Compliance to oversee strategy.
 - **Policy Overhaul:** Update governance policies to include organization-wide data handling, privacy standards, and acceptable use policies, not just IT ops.
 - **Strategic Cadence:** Shift governance meetings from "incident-only" to a monthly strategic review of risk appetite and compliance roadmap.
-

Section 3: Conduct Risk Assessment

3.1 Identified Risks

- **Cybersecurity (High):** *Unauthorized Database Access.* Weak encryption and insufficient access controls on the Cloud Database expose sensitive client data to potential breaches.
- **Operational (Medium):** *Delayed Incident Resolution.* The ITSM platform lacks standardized processes/SLAs, leading to inconsistent response times for critical issues.
- **Compliance (High):** *Missed Compliance Audits.* SOC 2 monitoring is manual and inconsistent, significantly increasing the risk of audit failure and loss of certification.

3.2 Recommendations for Risk Mitigation

- **Enhance Access Controls:** Immediately implement Multi-Factor Authentication (MFA) and robust encryption (AES-256) for the Cloud Database.
 - **Standardize ITSM Workflows:** Define clear Service Level Agreements (SLAs) and automated escalation paths within the ITSM platform to ensure timely resolution.
 - **Automate Compliance Monitoring:** Deploy automated controls to track SOC 2 criteria continuously rather than relying on manual spot checks.
-

Section 4: Review Compliance Requirements

4.1 Compliance Status

- **SOC 2: At Risk.** While the goal is to ensure data integrity and availability, current monitoring is inconsistent. The reliance on manual logs makes demonstrating continuous compliance during an audit difficult.
 - **GDPR: Non-Compliant.** There are no formal policies for cross-border data transfers or PII handling. Given DataTrust's growth, this poses a severe legal liability for EU clients.
 - **Internal Policies: Partial Adherence.** Cybersecurity training is mandated but irregular. There is no evidence of a formalized, recurring training schedule for the 600-person workforce.
-

Section 5: Assess GRC Integration

5.1 Integration Observations

- **Fragmented Approach:** Governance, Risk, and Compliance operate in silos. Risk data (spreadsheets) is not linked to Compliance controls (manual logs), and Governance decision-making is disconnected from both.
- **Manual Disconnects:** The lack of integration between the IDS and the risk tracking mechanism means threats detected by the IDS do not automatically trigger a risk review or policy update.

5.2 Recommendations for Integration

- **Unified GRC Framework:** Adopt a framework where a risk identified in the Cloud Database automatically triggers a review of the associated SOC 2 control and GDPR policy.
 - **Cross-Departmental Collaboration:** Mandate joint review sessions where IT (managing IDS/ITSM) shares data directly with Compliance to align technical reality with regulatory requirements.
-

Section 6: Analyze GRC Tools and Technology

6.1 Current Tools and Technology

- **Spreadsheets:** Used for risk tracking. They are static, prone to version control errors, and cannot provide real-time visibility.
- **Manual Compliance Logs:** Used for compliance tracking. This is time-consuming, unscalable for a 600-person company, and lacks audit trails.

- **Intrusion Detection System (IDS):** Functional but has limited automation, requiring manual intervention to analyze alerts.

6.2 Recommendations for Technology Upgrades

- **Deploy a dedicated GRC Platform:** Implement a tool (e.g., Vanta, Drata, or ServiceNow GRC) to replace spreadsheets. This will centralize risk registers and automate evidence collection for SOC 2.
 - **Enhance IDS Automation:** Upgrade or configure the IDS to automatically feed critical alerts into the ITSM platform for immediate ticketing.
 - **Compliance Dashboard:** Utilize a dashboard to visualize real-time compliance posture, replacing manual logging.
-

Section 7: Report Findings and Action Plan

7.1 Key Findings DataTrust Solutions has outgrown its "start-up" style processes. The reliance on spreadsheets and manual logs creates a high margin for human error. The most critical gap is the lack of GDPR data transfer policies, which could halt business expansion. Governance is currently too reactive, focused on fixing problems after they happen rather than preventing them.

7.2 Action Plan

1. **Immediate (0-30 Days):**
 - Conduct a GDPR gap analysis and draft data transfer policies.
 - Implement encryption and MFA on the Cloud Database.
 2. **Short Term (30-90 Days):**
 - Form the cross-functional GRC Committee.
 - Select and procure a dedicated GRC software platform.
 - Standardize ITSM incident workflows with defined SLAs.
 3. **Long Term (3-6 Months):**
 - Migrate all risk and compliance data from spreadsheets to the new GRC platform.
 - Conduct a mock SOC 2 audit to test the new automated controls.
 - Launch a company-wide quarterly cybersecurity training program.
-

Conclusion

DataTrust Solutions is at a pivotal growth stage where its GRC maturity must match its operational scale. The current fragmented and manual approach poses significant risks to client trust and regulatory standing. By centralizing governance, automating risk and compliance processes via a dedicated platform, and specifically addressing the GDPR and SOC 2 gaps, DataTrust can

transform its GRC function from a liability into a strategic enabler for future expansion. Immediate action on the Cloud Database security and GDPR policies is strongly recommended.